EUROPEAN SMBs · SHOPS · AGENCIES

YOUR BUSINESS HAS BEEN

HACKED

Now What?

THE FIRST 24 HOURS

Respond, contain, preserve evidence and notify under the GDPR



PLUS **9** Ready-to-use Templates

72-HOUR GDPR CLOCK

CONTAIN & PRESERVE

NOTIFY & RECOVER

HOUR-BY-HOUR PLAN · CHECKLISTS · NOTICE DRAFTS

ZIRLANDIA MILKOVIC



YOUR BUSINESS HAS BEEN

HACKED

Now What?

THE FIRST 24 HOURS

The First 24 Hours of a Cybersecurity Incident: immediate response, containment, evidence, and GDPR breach assessment and notification

ZIRLANDIA MILKOVIC

FOR EUROPEAN SMBs · SHOPS · AGENCIES

Your Business Has Been Hacked. Now What?

The First 24 Hours of a Cybersecurity Incident: immediate response, containment, evidence, and GDPR breach assessment and notification

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced, stored or transmitted in any form without written permission, except for brief quotations in reviews and for printing the worksheets, checklists and the notice templates for your own business use.

NOT LEGAL ADVICE. This book is an educational guide to the EU General Data Protection Regulation (Regulation (EU) 2016/679). It is not legal advice, does not create a lawyer-client or consultant-client relationship, and does not take your individual circumstances into account. Reading it, following it or using its templates does not make a business GDPR compliant and is not a certification or a guarantee of compliance.

LAWS CHANGE. Data protection law, regulatory guidance, court decisions and national rules develop continuously. The book reflects the author's understanding as of its publication date (2026) and refers to official sources so that you can check what applies now. National laws, supervisory-authority guidance and sector rules differ between countries. Before you rely on anything here for a decision with real consequences, take advice from a qualified lawyer or data protection professional in the relevant country.

Product and company names (for example email, analytics, advertising and AI platforms) are the property of their respective owners and are used only as examples for identification and education. This independent book is not affiliated with, sponsored by or endorsed by any of them, and no product is recommended or certified as compliant.

Every person, business and incident described in the case studies and scenarios is fictional and was created to illustrate ideas. Any resemblance to real people or companies is coincidental.

Premium Edition 2026 · PDF with clickable contents, bookmarks and fillable worksheets

Contents

Note	A Note from the Author	5
01	The First 24 Hours	6
02	Is This Really an Incident?	10
03	Hour Zero: Immediate Response	14
04	Containing the Incident	18
05	Preserving Evidence	22
06	Working Out What Happened	26
07	The GDPR Breach Assessment	30
08	Notifying the Authority	35
09	Telling the People Affected	39
10	The 24-Hour Plan, Hour by Hour	43
11	After the First 24 Hours	46
Bonus	Incident Toolkit	49
A–Z	Plain-English Glossary	54
Ref	Official Sources & Further Reading	55
Bio	About the Author	56

A Note from the Author

Why this book is about the first 24 hours, and why you should read it before you need it.

Nobody forgets the moment. A strange email from the finance mailbox. A screen that says your files are encrypted. A customer calling to say they received a message from "you" that you never sent. Your stomach drops, and in the next few minutes you will make decisions that shape the next few months.

Most small businesses do not fail because they were attacked. Attacks are close to unavoidable now. They get hurt because of what happens next: the panic, the delay, the machine switched off and the evidence lost, the password reset that tips off the attacker, the 72-hour clock that nobody noticed was running, the customers who heard about it from someone else.

The first 24 hours do not decide whether you are attacked. They decide how bad it gets.

This book is written for owners, managers and office leads at European small businesses, online shops and agencies, people who are not security engineers and have no incident team on call. It walks through the day in order: the first hour, containing the damage, preserving evidence, working out what data was involved, deciding whether the GDPR requires you to notify the authority or the people affected, and telling everyone what they need to know. At the back is a toolkit of ready-to-fill sheets: a 24-hour tracker, a contact card, an evidence log, a breach register and drafts of the notices you may have to send.

> AI & PRIVACY **How to use this book**
>
> **If you are under attack right now**, turn to the Quick-Start card at the start of Chapter 3 and the hour-by-hour plan in Chapter 10. Read the rest afterwards. **If you are not**, read it through once, fill in the Bonus contact card, and put a copy where you can reach it when your laptop and email are down. That one hour of preparation is worth more than anything in the next chapters.

PART I · UNDERSTAND THE DAY

CHAPTER

01

The First 24 Hours

Why the first day matters more than every day that follows, and the five things that must happen in it.

IN THIS CHAPTER

- Why the first 24 hours decide the size of the damage
- The five jobs of the first day, in order
- The mistakes that turn an incident into a disaster
- How the GDPR 72-hour clock fits into the day

It is 9:40 on a Tuesday. The owner of a twelve-person online shop notices that the order system will not load. Then a message appears on the office manager's screen: all files are encrypted, pay in cryptocurrency within 72 hours. Nobody has a plan. Someone suggests restarting the server. Someone else starts forwarding the message to the whole team. Within an hour, three people have rebooted their computers, a supplier has been emailed from the compromised account, and the one clean backup is still connected to the network.

Nothing about this attack was unusually clever. Almost everything that made it worse happened *after* it began.

Why the first day matters

Early on, an incident is small and fixable. Every hour that passes without action gives an attacker more time to spread, steal more data and cover their tracks. At the same time, every hasty action risks destroying the evidence you need, alerting the attacker or breaking systems you will want to recover. The first 24 hours are a narrow path between doing too little and doing too much.



The first day in four numbers

GDPR IN PLAIN ENGLISH **The clock starts at awareness**

The 72 hours in Article 33 run from the moment you become **aware** of a personal data breach, meaning you have a reasonable degree of certainty that a security incident has compromised personal data. They do not run from the moment you were hacked, which may have been weeks earlier, and they do not wait until the investigation is finished. You may send the notification in phases as facts emerge.

The five jobs of the first day

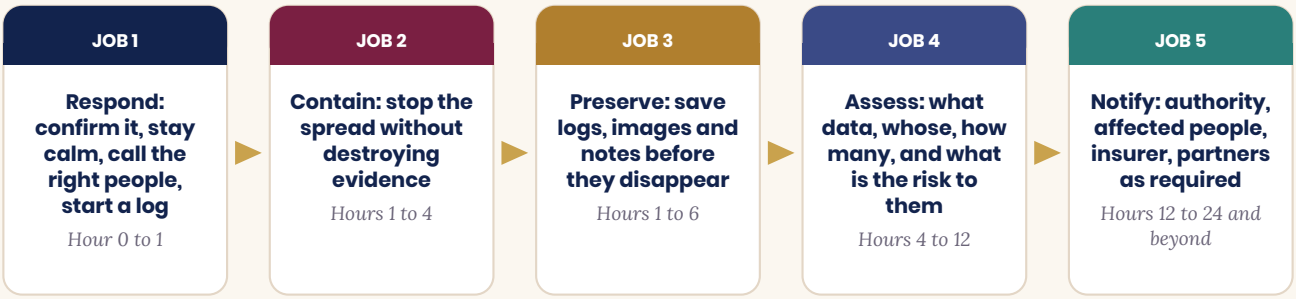


Figure 1 Your first 24 hours in five jobs

The order matters, but the jobs overlap. You will start preserving evidence while you are still containing, and you will begin the assessment before containment is finished. The rest of the book takes each job in turn.

The mistakes that make it worse



Figure 2 Four panic reflexes to resist

REAL-WORLD SCENARIO **Real-world scenario: the helpful reboot**

A small accounting firm finds one workstation behaving strangely. An employee reboots it "to see if it fixes things", then a colleague reinstalls the operating system the next morning. Two weeks later the firm learns that client tax files were copied. The investigators cannot say which files, because the logs and the machine's memory are gone. With no evidence either way, the firm has to assume the worst and notify every client.

What regulators have said

Regulators do not punish a business for being attacked. They look at whether you protected data properly beforehand and whether you handled the breach correctly afterwards. Two widely reported examples from the UK Information Commissioner, who enforces the UK version of the GDPR, show how large these fines can become. In October 2020 British Airways was fined £20 million after attackers accessed the personal data of over 400,000 customers and staff, and Marriott International was fined £18.4 million over a breach exposing hundreds of millions of guest records. In both cases the final figures were far lower than first proposed, partly because the companies notified promptly and cooperated.

You are unlikely to face a fine of that size, but the lesson scales down well: **fast notification, honest cooperation and good records are treated as mitigating factors.** That is what this book helps you build.

> DO THIS NOW **Do this now**
>
> Write down, today, three names: who in your business decides what happens in an incident, who to call for technical help, and who handles communication. If you cannot name them, you will lose your first hour finding out.

PART I · UNDERSTAND THE DAY

CHAPTER

02

Is This Really an Incident?

The common ways small businesses get hacked, the early warning signs, and how to tell a scare from an emergency.

IN THIS CHAPTER

- The six most common incident types in small businesses
- The warning signs that should make you stop and check
- A five-question triage that takes ten minutes
- The difference between a security incident and a personal data breach

Not every odd email is an attack, and not every attack involves personal data. But a business that treats every warning as nothing will eventually miss the real one. This chapter gives you a quick way to decide, in minutes, whether to start the incident process.

Six ways small businesses get hacked

01
PHISHING
A convincing email or text tricks someone into entering a password or opening an infected file. The most common starting point of all.

02
ACCOUNT TAKEOVER
Someone logs in as an employee, often with a stolen or reused password and no multi-factor authentication. Email and cloud accounts are the favourite targets.

03
RANSOMWARE
Files are encrypted and a payment is demanded. Many attackers also steal the data first, so restoring from backup does not end the problem.

04
BUSINESS EMAIL COMPROMISE
An attacker reads your email, then sends fake invoices or bank-detail changes in your name. Money and data both leave.

05
LOST OR STOLEN DEVICE
An unencrypted laptop, phone or USB stick goes missing. Not a hack, but often a reportable breach.

06
SUPPLIER BREACH
A tool or service provider you use is hacked and your customers' data goes with it. You are still responsible as the controller.

Figure 3 The usual suspects

Warning signs

Treat any of these as a reason to pause and check, especially if two appear together.

- Files that will not open, have strange new extensions, or a message demanding payment.
- Colleagues or customers reporting emails from you that you did not send.
- Password-reset or login alerts you did not trigger, or logins from unusual places or hours.
- New forwarding rules or filters in a mailbox that nobody created.
- Antivirus or security tools switched off, or unknown software and admin accounts.
- A supplier, bank or payment provider telling you about suspicious activity.

- Your data appearing online, or someone contacting you with information they should not have.
- A device lost, stolen or left somewhere it should not have been.

The ten-minute triage

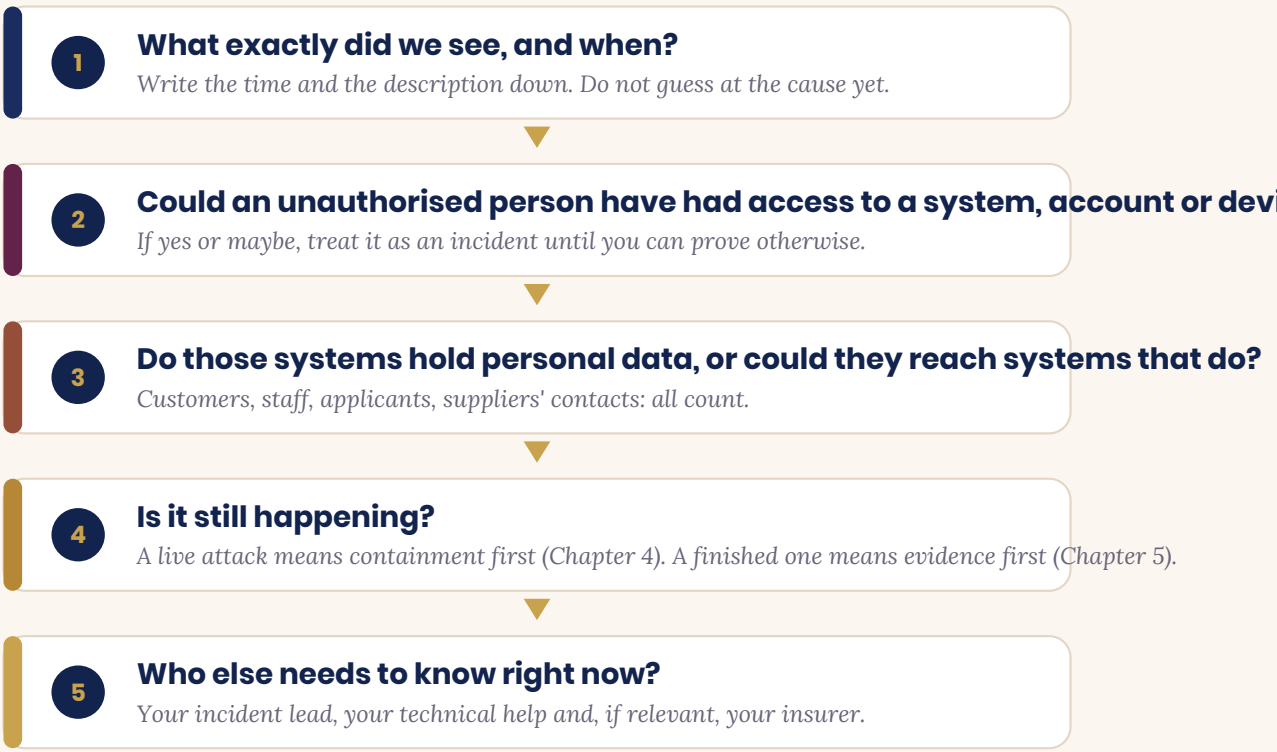


Figure 4 Ask these five questions, in this order

> **FOUNDER TIP** **When in doubt, start the log**
>
> Opening an incident log costs you five minutes. Declaring "nothing happened" and being wrong costs you days. If you are unsure, start the log and downgrade later. You can always close an incident, but you cannot recreate the first hour you ignored.

Security incident or personal data breach?

The two terms overlap but are not the same, and the difference drives your legal duties.

SECURITY INCIDENT

- Any event that threatens the confidentiality, integrity or availability of your systems or information.
- Includes attacks that touched no personal data.
- Handled through your own incident process, insurer and technical help.
- No GDPR notification duty by itself.

PERSONAL DATA BREACH

- A security breach that leads to accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data (Art. 4(12)).
- Includes lost devices, misdirected emails and encrypted records, not only hacking.
- Must be recorded in every case (Art. 33(5)).
- Must be reported to the authority unless unlikely to result in a risk to people (Art. 33).

Figure 5 Two terms, two sets of duties

WATCH OUT **Ransomware is usually a breach**

Even if no data was copied, encrypting your customer records can make them unavailable, which is an **availability** breach. Whether you must notify depends on the risk to people, for example whether you can restore quickly and whether anyone depends on the data urgently. Treat it as a potential breach from the start.

PART II · RESPOND AND CONTAIN

CHAPTER

03

Hour Zero: Immediate Response

The first sixty minutes: declare the incident, assemble a small team, open a log and make the first safe moves.

IN THIS CHAPTER

- A one-page Quick-Start for the first hour
- Who needs to be on your incident team, even in a tiny business
- How to run the incident log that protects you later
- What to say to staff, and what to keep quiet

DO THIS NOW **Quick-start: the first hour**

1. Write down the time and what you saw. **2.** Tell your incident lead. **3.** Disconnect affected devices from the network (unplug the cable, switch off Wi-Fi), but do **not** power them off. **4.** From a clean device, change passwords and sign out sessions for affected accounts. **5.** Call your technical help and your insurer. **6.** Start the incident log. **7.** Tell staff to stop, not to delete anything and not to discuss it outside the team.

Step 1: Declare it

The first decision is psychological. Someone must say, out loud, "We are treating this as an incident." Until that happens, everyone keeps working, evidence keeps changing and nobody is in charge. Declaring does not mean you are certain. It means you have switched to a different mode of working.

Step 2: Assemble the smallest useful team

You do not need a security operations centre. You need four roles, which in a small business may be only two or three people.

01
INCIDENT LEAD
Owns decisions and the clock. Usually the owner or managing director. Decides what is contained, who is told and when.

02
TECHNICAL LEAD
Your IT person, managed service provider or an external responder. Carries out containment and evidence capture.

03
PRIVACY LEAD
The person responsible for data protection, or the DPO if you have one. Runs the breach assessment and the notifications.

04
COMMS LEAD
Handles staff, customers, partners and press. Keeps every message consistent and approved.

Figure 6 The four incident roles

FOUNDER TIP **One person writes everything down**

Give one person the job of **scribe**. They record every action, time, decision and who made it. It is the most valuable role in a small team, because nobody remembers anything accurately after a stressful day, and regulators, insurers and lawyers will ask.

Step 3: Open the incident log

Use a simple document or notebook kept **outside** the affected systems: a clean device, a personal account that is not compromised, or paper. If the attacker controls your email and cloud drive, a log stored there is not safe.

What every log entry contains

Field	Example
Date and time (with time zone)	12 Nov 2026, 10:42 CET
What happened or what was done	Finance mailbox forwarding rule found, rule deleted
Who did it or reported it	Maria (office manager)
Why	To stop copies of invoices leaving
Result or follow-up	Mailbox password reset; rule recreated at 10:55, so account still compromised

Step 4: Make the first safe moves

Early actions should be reversible and should not destroy anything. Think of it as stopping the bleeding, not performing the surgery.

- **Isolate, do not power off.** Disconnect network cables and switch off Wi-Fi on affected machines. Leave them running so memory contents remain.
- **Use a clean channel.** Talk by phone or a messaging app on personal devices, not through the compromised email or chat.
- **Secure the accounts.** From a trusted device, reset passwords and revoke active sessions for affected users, starting with administrators and email.
- **Pause outgoing risk.** Stop payments in progress and warn finance not to act on any bank-detail changes until verified by phone.
- **Photograph, do not fix.** Take photos or screenshots of ransom notes and error messages with a phone.

> WATCH OUT **Do not pay, delete or confront**
>
> Do not pay a ransom or reply to the attacker before taking advice, as payment does not guarantee anything and may carry legal risk. Do not delete suspicious files or emails; quarantine them. Do not contact the attacker.

Step 5: Make the first calls



Figure 7 Who to call, in this order

Step 6: Brief the team

Staff are your best sensors and your biggest risk. Give a short, calm instruction:

> *"We have a security problem. Please stop using the affected systems, do not delete or forward anything, do not talk about it outside the company, and send every question to the incident lead."*

Avoid speculation, blame and rumours on social media. If someone clicked a link, thank them for reporting it. People who fear punishment hide mistakes, and hidden mistakes are the expensive ones.

PART II · RESPOND AND CONTAIN

CHAPTER

04

Containing the Incident

How to stop the spread without breaking your evidence, for ransomware, stolen accounts and compromised devices.

IN THIS CHAPTER

- The difference between containment, eradication and recovery
- Short-term containment steps that are safe for most businesses
- Specific playbooks for ransomware, email compromise and lost devices
- How to deal with suppliers and processors during an incident

Containment means limiting how far the attacker can go and how much damage they can do, while keeping the option to investigate and recover. It comes before cleaning up. A common beginner's mistake is to rush to "fix" things, which usually means deleting the traces and leaving the door open.

Three phases, not one

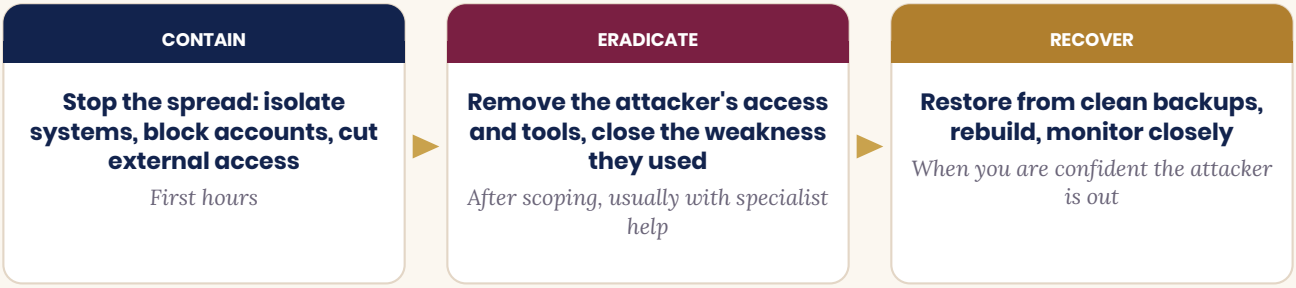


Figure 8 From containment to recovery

> **WATCH OUT** **Do not recover too early**
>
> If you restore systems while the attacker still has access, they simply encrypt or steal again. Recovery should begin only when you understand how they got in and have closed that route.

Short-term containment checklist

FIRST-DAY CONTAINMENT

- [ ] Affected devices disconnected from the network (cable out, Wi-Fi off) but still powered on.
- [ ] Passwords reset for affected accounts, starting with administrators, email and finance, from a clean device.
- [ ] Active sessions and tokens revoked, and multi-factor authentication enabled or reset.
- [ ] Mailbox rules, forwarding addresses, delegated access and connected apps reviewed and unknown ones removed.
- [ ] Remote access tools, VPN accounts and shared logins disabled until verified.
- [ ] Backups checked and disconnected from the network so they cannot be encrypted.
- [ ] Payments and bank-detail changes frozen until confirmed by phone.
- [ ] Staff told which systems to avoid and which clean channel to use.

Playbook: ransomware

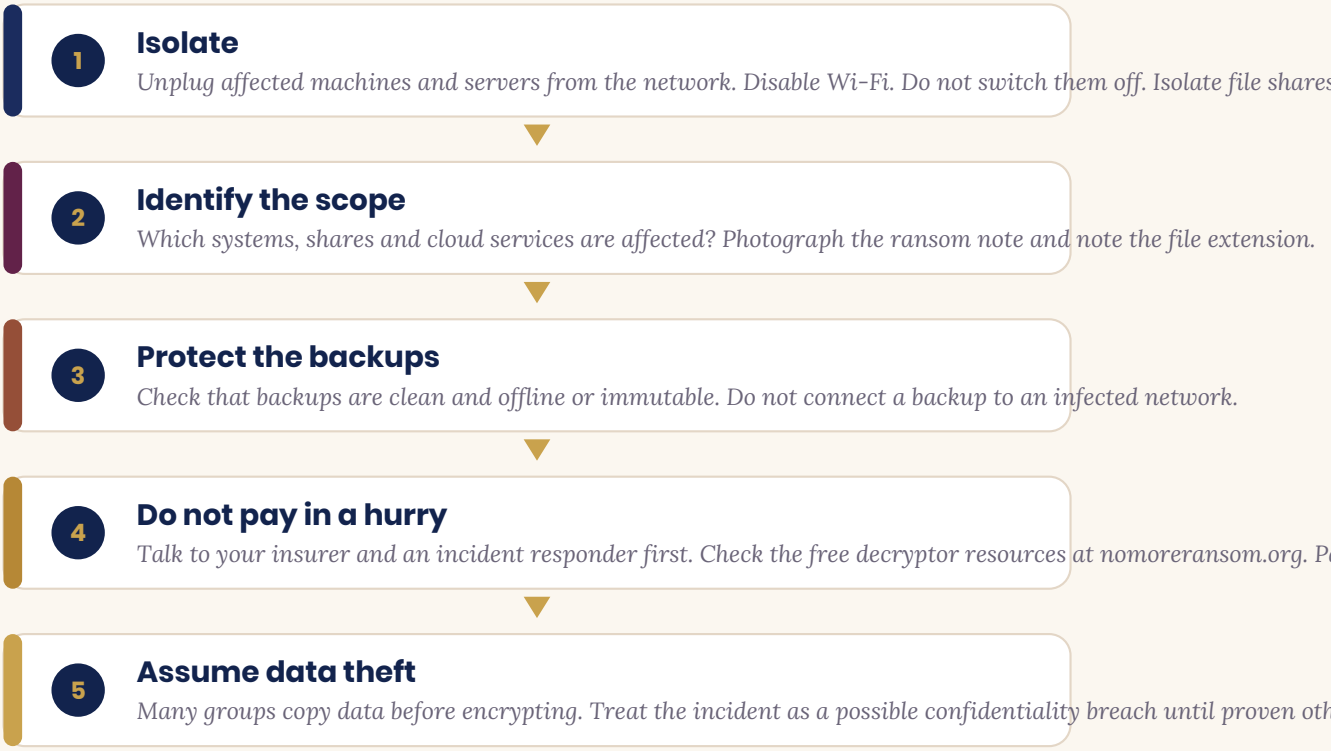


Figure 9 When files are encrypted

Playbook: email or cloud account takeover

- Reset the password and sign out all sessions from a trusted device. Turn on multi-factor authentication.
- Look for new mailbox rules, forwarding to unknown addresses, new devices, new app authorisations and changes to bank details in sent mail.
- Review the sign-in history for the account to see when the attacker first got in.
- Warn colleagues, customers and suppliers who may have received malicious messages, using a clean channel.
- Check whether the same password was used anywhere else and change those too.

Playbook: lost or stolen device

- Record what the device was, when it was lost and who had it.
- Use remote lock and wipe if available. Note whether the device was encrypted, since encryption can greatly reduce the risk to people.
- Revoke the user's sessions and change their passwords.
- List what personal data the device could access, including synced email and cloud files.
- Report theft to the police if appropriate and keep the reference number.

> **GDPR IN PLAIN ENGLISH** **Encryption can change the answer**
>
> If lost data was properly encrypted and the key was not compromised, the data may be unintelligible to anyone who gets it. That can mean there is **no high risk to people**, and the duty to inform them (Art. 34(3)(a)) may not apply. You must still record the breach, and the notification decision still needs reasoning.

When a supplier is the problem

If a processor such as your hosting company, email provider or payroll tool is breached, they must tell you without undue delay (Art. 33(2)). **Your 72-hour clock starts when you become aware**, which is usually when they tell you. Ask them for the details in writing: what happened, what data, how many people, what they have done and what they need from you.

What to ask a supplier that has been breached

Question	Why it matters
When did the incident start and when was it discovered?	Sets your timeline and shows whether notice was prompt
Which of our data was affected, and how many records?	Drives your risk assessment and notices
Was the data encrypted or readable?	Changes the risk to people
Has the attacker been removed and how do you know?	Tells you whether the data is still exposed
What do you need from us, and what are you telling regulators?	Avoids contradicting each other

PART III · INVESTIGATE AND ASSESS

CHAPTER

05

Preserving Evidence

What to save, how to save it, and why careless clean-up can leave you unable to prove anything.

IN THIS CHAPTER

- Why evidence matters for the GDPR, insurance, the police and your own defence
- What to preserve in the first hours, in order of how quickly it disappears
- A simple chain-of-custody habit any small business can follow
- When to bring in a forensic specialist

Evidence answers the questions everyone will ask: how did they get in, what did they touch, what did they take, and when did it stop? Your regulator, your insurer, your lawyers, your customers and the police all want those answers. Without evidence, you must assume the worst, notify more people and defend yourself with nothing.

Why it matters under the GDPR

The GDPR's accountability principle (Art. 5(2)) requires you to be able to demonstrate compliance. For breaches, Article 33(5) goes further: you must **document every personal data breach**, including its facts, its effects and the remedial action taken, so the authority can verify your compliance. Evidence is what gives that record substance.

What to save first

Some evidence vanishes in minutes, some lasts for weeks. Preserve in order of volatility.

Order of volatility: save the top first

Priority	What	Why it is urgent
1	Live state	Open sessions, running processes, memory of affected machines. Lost if you power off.
2	Logs	Email, firewall, VPN, cloud and application logs. Often overwritten after days or weeks.
3	Disk and files	Affected machines, ransom notes, suspicious files, malware samples.
4	Messages	Phishing emails with full headers, attacker messages, call recordings.
5	Paperwork	Your own notes, screenshots, timelines and decisions.

The evidence checklist

PRESERVE BEFORE YOU CLEAN

- [ ] Photos or screenshots of ransom notes, error messages and suspicious pop-ups, with the date and time visible.
- [ ] Original suspicious emails saved in full, with headers, not just forwarded copies.
- [ ] Sign-in logs, admin audit logs and mailbox audit logs exported from email and cloud providers.
- [ ] Firewall, VPN, web server and application logs copied to a safe location.
- [ ] A list of affected devices with make, serial number, user and location.
- [ ] Disk images or memory captures made by a specialist where the incident is serious.
- [ ] Backups from before and after the incident kept untouched.
- [ ] Your incident log and every decision recorded.

WATCH OUT **Logs have a short shelf life**

Many cloud services keep detailed logs for only 30, 90 or 180 days, and some plans keep far less. Export them on day one, even if you do not yet know what you are looking for.

Keep a chain of custody

Chain of custody simply means being able to say who held a piece of evidence, when, and that it was not changed. You do not need legal training. You need a habit.



Figure 10 The four-step habit

Evidence log example

Item	Source	Collected by	Date and time	Stored at
Ransom note screenshot	Finance PC	Maria	12 Nov 10:45	Encrypted USB 1, safe
Mailbox audit log (30 days)	Microsoft 365 admin	Jan	12 Nov 11:20	Encrypted USB 1, safe
Phishing email with headers	Maria's mailbox	Jan	12 Nov 11:35	Encrypted USB 1, safe
Disk image, finance PC	Finance PC	External responder	12 Nov 14:10	Responder vault; copy ref. #4

When to call in a specialist



Figure 11 Signs you need forensic help

FOUNDER TIP **Check your insurance now**

Many cyber policies include a 24-hour incident hotline, approved forensic firms and legal support. Using someone else may void cover. Find your policy number and the hotline and put them on your contact card today.

PART III · INVESTIGATE AND ASSESS

CHAPTER

06

Working Out What Happened

Scoping the incident: which systems, which data, whose, and how many, with the facts you have by the end of the first day.

IN THIS CHAPTER

- The questions that define the scope of an incident
- How to build a short timeline from imperfect facts
- What to do when you cannot be certain
- A fact sheet you update every few hours

By hour four or five the immediate fires are out and you face the most important question for the GDPR: **what happened to the personal data?** You will not have the full answer. You need enough of it to assess risk, and a method for updating it as facts arrive.

The nine scoping questions

1. **How did the attacker get in?**
   Phishing, stolen password, unpatched system, exposed service, supplier, insider or lost device.
2. **When did it start and when did we find out?**
   The gap between the two matters. Awareness starts the 72-hour clock.
3. **Which systems and accounts were touched?**
   Email, shop, CRM, file shares, HR, payment tools, backups.
4. **What data sits on those systems?**
   Use your records of processing and system register if you have them.
5. **Whose data is it?**
   Customers, staff, applicants, suppliers, children, patients.
6. **Roughly how many people?**
   A range is acceptable early on. Refine it.
7. **Was the data copied, changed, deleted or only exposed?**
   Confidentiality, integrity and availability are different breaches.
8. **Was the data encrypted or readable?**
   Strongly affects the risk to people.
9. **Is the attacker still in?**
   Changes everything about containment.

Figure 12 Answer as many as you can, mark the rest "unknown"

Build a timeline

A one-page timeline makes the story clear to you, your adviser and the authority. Start with what you know for certain and mark the rest as estimates.

Day -9 — **Phishing email received**
A staff member enters their password on a fake login page. The attacker signs in the same evening.

Day -8 — **Silent monitoring**
The attacker sets a hidden forwarding rule and reads client emails for several days.

Day 0, 09:15 — **Fake invoice sent**
A client receives an altered bank-detail invoice. They phone the agency to check.

Day 0, 09:40 — **Incident declared**
The owner opens the log and isolates the account. The clock starts: awareness at 09:40.

Day 0, 14:00 — **Scope understood**
Audit logs show 9 days of access and forwarding of 11 client mailboxes.

Figure 13 Example: a small agency under attack

> **GDPR IN PLAIN ENGLISH** **Awareness is not the same as being sure**
>
> The EDPB's breach guidance says you are "aware" when you have a **reasonable degree of certainty** that a security incident has compromised personal data. A short initial investigation is allowed so you can establish this, but it should start immediately and not drift. Once you are reasonably certain, the clock is running.

When you cannot be sure

You often cannot tell exactly what the attacker saw. Logs may be incomplete, or the access was broad. In that case:

- Assume the attacker could reach everything the compromised account or system could reach.
- Notify with the facts you have and say clearly what is still being investigated.
- Update the authority as you learn more. Article 33(4) allows information to be provided in phases.
- Record the reasoning. "We could not exclude access to the customer database, so we treated all 4,200 records as affected" is a defensible position.

The fact sheet

WORKSHEET

Incident fact sheet

Update this every few hours and date each version. It becomes the basis of your breach assessment and any notification.

Date and time we became aware

How the incident was detected

Systems and accounts affected

Types of personal data involved

Categories of people affected (customers, staff, others)

Approximate number of people and records

Was the data encrypted, copied, altered or deleted?

Is the attacker still active?

Actions taken so far

Still unknown

PART IV · DECIDE AND NOTIFY

CHAPTER

07

The GDPR Breach Assessment

Is it a personal data breach, how risky is it for people, and does the law require you to notify?

IN THIS CHAPTER

- The three types of personal data breach
- How to assess risk to people in plain steps
- The three possible outcomes: record only, notify the authority, notify the people
- How to document your decision so you can defend it

This is the legal heart of the first day. You take the facts from Chapter 6 and answer three questions in order. Write down the answers and the reasons for them, because the reasoning is what a regulator will examine.

Question 1: Is it a personal data breach?

Article 4(12) defines it as a breach of security leading to the **accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data**. The EDPB groups these into three types, and one incident can involve more than one.

CONFIDENTIALITY	INTEGRITY	AVAILABILITY
Someone who should not have the data has seen it or got a copy. Stolen databases, misdirected emails, compromised mailboxes.	Data was altered without permission. Changed bank details, edited records, tampered files.	Data is lost or inaccessible. Ransomware, deleted files, a destroyed device with no backup.

Figure 14 Three types of breach

Question 2: What is the risk to people?

The focus is the **people** whose data is involved, not the damage to your business. Article 33 asks whether the breach is "unlikely to result in a risk to the rights and freedoms of natural persons". Article 34 asks about "high risk". Consider these factors, drawn from the EDPB guidance.

Factors that raise or lower the risk

Factor	Higher risk	Lower risk
Type of breach	Confidentiality leak or deliberate theft	Brief loss of access with quick restore
Nature of the data	Health, financial, ID documents, passwords, children, special categories	Business contact details already public
Ease of identifying people	Names with addresses, national numbers	Properly pseudonymised or encrypted data
Number of people	Thousands	A handful
Severity of consequences	Fraud, discrimination, physical harm, loss of confidentiality	Minor inconvenience
Who has the data	Criminals, publishers, unknown parties	A trusted recipient who deleted it
Vulnerable people	Children, patients, people in a weak position	General business contacts

Rate it on the matrix

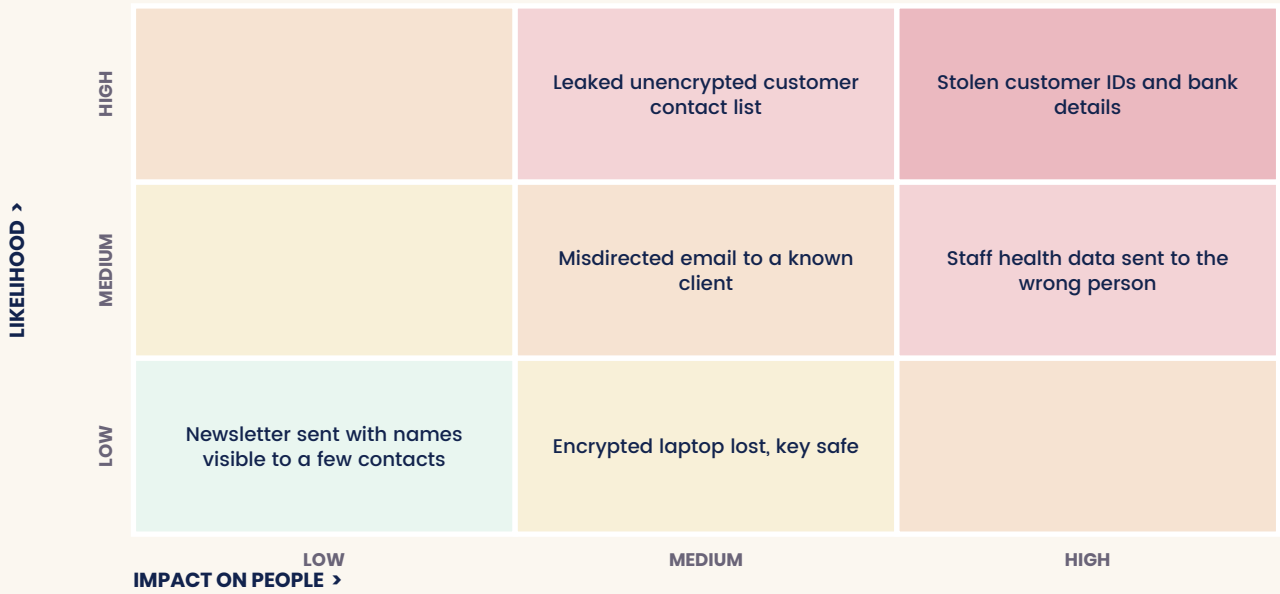


Figure 15 Likelihood of harm against severity for people

Question 3: What do I have to do?

1	**Is personal data involved in the incident?**	**YES** Continue to the next question	**NO** No GDPR breach duty. Keep the incident record.
2	**Is the breach unlikely to result in a risk to people?**	**YES** Record it internally (Art. 33(5)) and write your reasoning down. No notification needed.	**NO** Notify the supervisory authority within 72 hours (Art. 33).
3	**Is the breach likely to result in a high risk to people?**	**YES** Also tell the affected people without undue delay (Art. 34).	**NO** Authority only. Keep the reasoning.

Figure 16 Which duties apply?

WHAT GDPR REQUIRES **Three outcomes**

Unlikely to result in risk: document it internally, no notification. **Likely to result in a risk:** notify the supervisory authority within 72 hours. **Likely to result in a high risk:** notify the authority and the affected individuals without undue delay. When unsure, lean towards notifying, since the penalty for failing to notify is usually worse than the cost of an unnecessary report.

The exceptions for telling individuals

Article 34(3) lists three situations in which you do not have to inform individuals even when the risk is high: the data was **unintelligible** to anyone not authorised (for example strongly encrypted); you have taken **subsequent measures** that mean the high risk is no longer likely; or contacting each person would involve **disproportionate effort**, in which case you must use a public communication or similar instead. The authority can also order you to inform people.

WATCH OUT **Do not rely on a hunch**

"It's probably fine" is not an assessment. Write down the factors, your rating and your reasoning, and have a second person read it. If the authority disagrees with your conclusion later, a documented, reasonable decision is far easier to defend than an undocumented one.

Document the decision

WORKSHEET

Breach risk assessment

Complete this at hour 8 to 12, and again when facts change. Keep every version.

Type(s) of breach (confidentiality, integrity, availability)

Data categories involved

Approximate number of people

Likelihood of harm (1 to 3) and why

Severity of harm (1 to 3) and why

Decision: record only / notify authority / notify authority and individuals

Reasoning in two or three sentences

Assessed by and second reviewer

Date and time

PART IV · DECIDE AND NOTIFY

CHAPTER

08

Notifying the Authority

The 72-hour rule in practice: what to send, when, to whom, and what else may be required alongside it.

IN THIS CHAPTER

- What Article 33 requires and when the 72 hours end
- What to put in a notification, and how to send it in phases
- What to do if you miss the deadline
- Other reporting duties that can apply on the same day

What Article 33 says

If a personal data breach is likely to result in a risk to people, the controller must notify the competent supervisory authority **without undue delay and, where feasible, not later than 72 hours after having become aware of it**. If the notification is later than 72 hours, it must come with the **reasons for the delay**. A processor must notify its controller without undue delay after becoming aware.

> **GDPR IN PLAIN ENGLISH** **72 hours is calendar time**
>
> The 72 hours include weekends and public holidays. If you become aware on Friday at 16:00, the deadline is Monday at 16:00. Plan for this: you cannot wait for the office to reopen.

Which authority?

Normally you notify the data protection authority of the country where your **main establishment** is. If you only operate in one country, that is simple. If you have customers across the EU, the one-stop-shop mechanism usually means a single lead authority handles the case, but check the EDPB guidance and your authority's website, because most have an online breach form. Businesses without an EU establishment may have to notify the authority in each member state where affected people live.

What the notification must contain

Required content (Art. 33(3))

Element	What to include
Nature of the breach	What happened, the type of breach, categories and approximate number of people and records
Contact point	Name and details of your DPO or other contact who can give more information
Likely consequences	What could happen to the people affected, such as fraud, phishing, discrimination
Measures taken or proposed	What you did to contain it and reduce harm, and what you plan to do next

FOUNDER TIP **Send what you have, then add**

Article 33(4) allows you to provide information in phases when it cannot all be given at once. A first report that says "initial notification, investigation ongoing, we will update by [date]" is far better than silence while you wait for certainty.

If you miss the 72 hours

Do not hide it. File the notification as soon as you can, state honestly when you became aware, explain the reasons for the delay and set out what you did in the meantime. Authorities look at late notification as a factor, but concealing a breach is treated far more seriously than reporting one late.

Notify, document, repeat

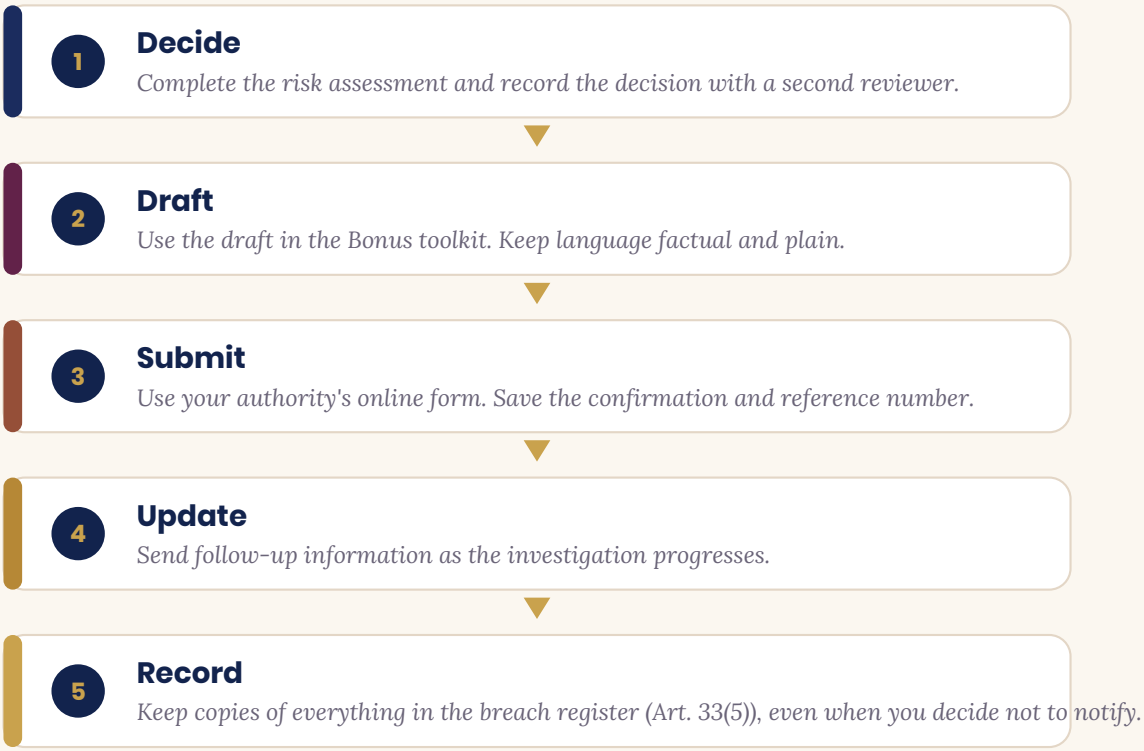


Figure 17 The notification routine

Other reports that may apply on the same day

The GDPR is only one of several duties. Check each of the following early, because they have their own deadlines.

Beyond the GDPR

Who	When to consider	Notes
Your cyber insurer	Immediately	Late notice can reduce or void cover
Police or national cybercrime unit	If a crime has occurred: ransomware, fraud, theft	Get a crime reference number for insurers and banks
National CSIRT or cyber authority	If NIS2 applies to your sector and size	Early warning within 24 hours, fuller notification within 72 hours, final report within one month
Payment provider or card schemes	If card data may be involved	Contracts often require immediate notice
Your bank	If funds or bank details were affected	Ask them to flag or recall payments
Customers and partners	If your contracts promise notice	Many B2B contracts require 24 to 72 hours
Sector regulators	Financial, health, telecoms and others	Rules differ widely by sector and country

WATCH OUT **NIS2 may apply to you**

The NIS2 Directive covers many medium and large businesses in sectors such as energy, transport, digital infrastructure, manufacturing, food and digital providers, with national laws setting the details. If you serve such a business as a supplier, you may also be contractually bound. Ask your adviser early whether it applies.

AI & PRIVACY **Reform is proposed, not law**

The European Commission's Digital Omnibus proposal would, among other things, raise the GDPR notification threshold to high-risk breaches, extend the deadline to 96 hours and create a single EU reporting point. As of late October 2026 these remain proposals going through the legislative process. **Today the 72-hour rule in Article 33 applies.** Check the current position before relying on any change.

PART IV · DECIDE AND NOTIFY

CHAPTER

09

Telling the People Affected

When you must tell individuals, what to say, and how to do it without making things worse.

IN THIS CHAPTER

- When Article 34 requires you to inform individuals
- What a good notification contains
- A plain-English template you can adapt
- How to prepare for the questions and complaints that follow

When you must tell people

Article 34 requires you to communicate the breach **to the affected individuals without undue delay** when it is **likely to result in a high risk** to their rights and freedoms. The point is practical: people can only protect themselves, by changing passwords, watching their accounts or being alert to fraud, if they know.

> **WHAT GDPR REQUIRES** **Clear and plain language**
>
> The message must describe the nature of the breach in **clear and plain language** and include at least: a contact point, the likely consequences and the measures taken or proposed (Art. 34(2), referring to Art. 33(3)(b) to (d)).

What a good message includes



Figure 18 Four things people need to know

A template you can adapt

Customer notification (draft)

```
Subject: Important information about your personal data

Dear [Name],

We are writing to tell you about a security incident that affected some of the personal data we
hold about you.

What happened: On [date] we discovered that [short description, e.g. an unauthorised person gain
ed access to our customer system].
What information was involved: [list the data, e.g. your name, email address and order history].
 [State clearly that payment card details / passwords were or were not included.]
What this could mean for you: [e.g. you may receive phishing emails that appear to come from us]
.
What we have done: We have [contained the incident, reset access, informed the data protection a
uthority, started an investigation with specialists].
What you can do: [change your password, be cautious of unexpected messages, check your statement
s].

You can reach us at [contact name, email, phone] with any questions. We are sorry this happened
and we will keep you informed.

[Name, role, business]
```

WATCH OUT **Do not minimise or blame**

Phrases like "a very small number", "no evidence of misuse" or "highly sophisticated attack" annoy people unless they are true and supported. Say what you know, say what you do not yet know and apologise plainly. Do not blame an employee or a supplier in public messages.

How to deliver it

- Use a **direct channel**: email, post or app message to each affected person. A website banner alone is not enough unless individual contact would be disproportionate.
- Send from an account you are sure is clean. Make it easy to verify that the message is real, for example by referring to your official site.
- Warn people that criminals may imitate your message, and say what you will never ask for (passwords, payment details).
- Prepare a short Q and A for staff who will take calls, and a dedicated address for questions.
- Keep a record of when and how each group was told.

REAL-WORLD SCENARIO **Real-world scenario: the second attack**

After a small online shop leaks its customer list, it sends a notification email containing a link to "check what was exposed". Within hours, criminals copy the layout and send fake versions with a link to a fraudulent page. Customers lose money. The shop's real notice should have contained no links asking for logins, only a phone number and the address of its official site.

Expect questions and complaints

Customers may ask for compensation, access to their data, or deletion of it. Article 82 gives people the right to claim damages for material or non-material harm resulting from infringements. Handle all requests promptly and politely, log them, and take advice before making any admission of liability. Staff should refer anything that sounds like a legal claim to the incident lead.



PART V · RUN THE DAY

CHAPTER

10

The 24-Hour Plan, Hour by Hour

Everything in this book on one timeline, plus how to talk to staff, customers and the press while it is happening.

IN THIS CHAPTER

- A complete hour-by-hour plan for the first day
- What to say to staff, customers and journalists
- How to handle a night or weekend attack
- How to hand over between tired people

The plan on one page

Hour 0 to 1 — **Respond**
Declare the incident, name the four roles, open the log outside the affected systems, isolate affected devices, secure key accounts, make the first calls.

Hour 1 to 4 — **Contain**
Work through the containment checklist, protect backups, freeze payments, begin evidence capture and export logs.

Hour 4 to 8 — **Scope**
Answer the nine scoping questions, build the timeline, complete the first version of the fact sheet.

Hour 8 to 12 — **Assess**
Run the breach risk assessment with a second reviewer. Decide: record only, authority, or authority and individuals.

Hour 12 to 18 — **Prepare**
Draft the authority notification and any customer notice. Inform insurer, partners, bank, police as needed.

Hour 18 to 24 — **Notify and stabilise**
Submit the notification if required, brief staff, plan the next day, hand over rested, and start recovery planning.

Figure 19 The first 24 hours

> **GDPR IN PLAIN ENGLISH** **You do not need to finish in a day**
>
> The GDPR gives you up to 72 hours for the authority notification, not 24. This plan aims to reach a decision within the first day so that you have the rest of the time to send, check and correct. Using a day for the decision leaves two days for quality.

Communicating in the middle of the storm

Staff

Tell them early, briefly and repeatedly. Explain what to do and what not to do, name one person for questions and promise regular updates, even when the update is "no change". Silence invites rumours.

Customers and partners

Do not inform everyone at once on a hunch. First decide who is affected, then tell them in order of risk and obligation. Keep a holding statement ready for those who ask before you are ready.

Holding statement (draft)

```
We have identified a security incident affecting some of our systems. We are investigating with specialists and have taken steps to contain it. We will contact anyone whose personal data is affected directly, as soon as we know more. If you have concerns, please contact [name, phone, email].
```

Press and social media

Appoint one spokesperson. Say what you know and what you are doing, never speculate about attackers or numbers, and never contradict what you told the authority. Check public messages against the facts in the fact sheet before posting.

> **WATCH OUT** **Consistency is a legal risk**
>
> Your notification to the authority, your message to customers and your public statement must tell the same story. Inconsistent numbers or timelines can look like concealment. Keep one fact sheet as the single source of truth and have the incident lead approve every outgoing message.

If it happens at night or on a weekend

- Keep the contact card printed and in more than one place. Email may be down.
- Agree who is allowed to authorise isolating a system without asking, so the night manager is not afraid to act.
- Have a mobile number for your technical help and your insurer's emergency line.
- Do not wait until Monday. The 72 hours include weekends.

Handover and rest

Incidents are marathons that start as sprints. People who have been awake for 18 hours make poor decisions. Plan shifts, make sure the log is current, and hold a ten-minute handover at each change: where we are, what is pending, what the next deadline is and what must not be touched.

END OF DAY ONE

- [ ] Incident declared, roles named, log up to date, systems contained and backups protected.
- [ ] Evidence preserved and the fact sheet updated within the last four hours.
- [ ] Breach risk assessment completed and decision recorded.
- [ ] Authority notified, or the reasoning for not notifying recorded.
- [ ] Insurer, bank, police and partners informed; staff briefed; next-day plan and handover written.

PART V · RUN THE DAY

CHAPTER

11

After the First 24 Hours

Recovery, learning and the preparation that makes next time smaller.

IN THIS CHAPTER

- What happens in days two to thirty
- How to restore safely and keep the attacker out
- How to run a blameless review
- Ten steps to be ready before the next incident

Days two to thirty

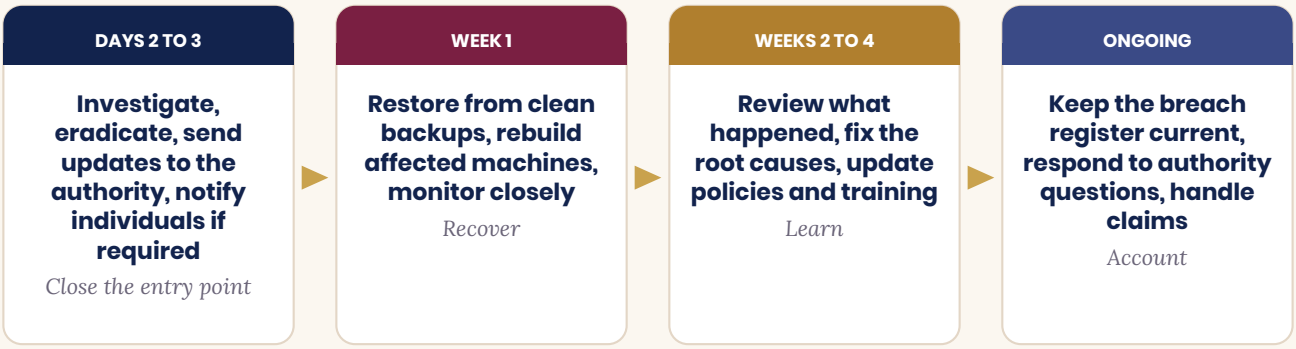


Figure 20 After the first day

Recover safely

- Rebuild affected machines from known-good media rather than "cleaning" them.
- Restore data from backups taken **before** the attacker arrived, and scan them first.
- Reset all passwords and keys that could have been exposed, including service accounts and API keys.
- Turn on multi-factor authentication everywhere it is available, starting with email, admin and finance.
- Monitor logs and accounts closely for several weeks. Attackers often return.
- Re-check suppliers, remote access and any new accounts created during the incident.

Run a blameless review

Within two to four weeks, gather the people involved and ask: what happened, what went well, what went badly, what surprised us and what will we change? The aim is learning, not punishment. A team that fears blame will hide the next incident.

Review output

Question	Example answer
What allowed the attack?	No multi-factor authentication on email
What slowed us down?	Nobody knew the insurer's hotline
What went well?	Staff reported the phishing email within minutes
What will we change, by whom, by when?	MFA on all accounts, owner Jan, within 14 days

Keep the breach register

Article 33(5) requires a record of **every** personal data breach, whether or not you notified. Keep one simple register: date, facts, effects, actions, the notification decision and the reasoning. The Bonus toolkit includes a template. Inspectors often ask for it first.

Ten steps to be ready next time

1. Appoint an incident lead, a deputy and the other three roles.
2. Fill in and print the contact card, and keep copies outside your systems.
3. Turn on multi-factor authentication on email, cloud, admin and finance accounts.
4. Keep tested, offline or immutable backups of what matters.
5. Know what personal data you hold and where, with a basic record of processing.
6. Keep logs long enough to investigate, and know how to export them.
7. Sign data processing agreements that require suppliers to report breaches promptly.
8. Train staff to spot phishing and to report mistakes without fear.
9. Check your cyber insurance and keep the hotline number handy.
10. Practise once a year with a one-hour tabletop exercise.

FOUNDER TIP **Run a one-hour drill**

Pick a scenario, such as "the finance mailbox was compromised". Walk through this book with your team: who does what, who is called, what is the fact sheet, what is the decision. The gaps you find in an hour of talking would otherwise appear in the first hour of a real attack.

GDPR IN PLAIN ENGLISH **Prevention is part of the law**

Article 32 requires appropriate technical and organisational measures to secure personal data, taking account of risk and cost. Regulators judge breaches partly by whether you had sensible protections in place. The most useful controls for a small business are rarely expensive: MFA, patching, backups, least-privilege access and training.

BONUS

T

Incident Toolkit

Contact card, 24-hour tracker, evidence log, breach register and ready-to-adapt notices. Fill them in on screen or print them.

IN THIS CHAPTER

- A contact card for the people you will need
- A 24-hour action tracker
- An evidence log and a breach register
- Draft notices for the authority and for individuals

WATCH OUT **How to use the toolkit**

The tables have fillable fields in the PDF and ruled boxes in print. Complete the contact card **before** you need it and keep a printed copy away from your systems. These are educational templates, not legal advice: adapt them to your business and check requirements in your country.

WORKSHEET

Incident contact card

Fill this in now. Print it and keep copies in two physical places.

Incident lead (name, mobile)

Deputy (name, mobile)

Technical help / IT provider (name, 24h number)

Privacy lead or DPO (name, mobile)

Communications lead (name, mobile)

Cyber insurer (policy number, incident hotline)

Lawyer or adviser (name, number)

Bank fraud contact

Supervisory authority breach form (web address)

Police / cybercrime reporting contact

Key suppliers' emergency contacts

24-HOUR ACTION TRACKER

Hour	Action	Owner	Done at	Notes
e.g. 0 to 1	*Declare incident, open log*	*Incident lead*	*09:40*	*Log on paper*

EVIDENCE LOG

Item	Source	Collected by	Date and time	Stored at
e.g. Ransom note screenshot	*Finance PC*	*Maria*	*12 Nov 10:45*	*Encrypted USB 1*

DECISION LOG

Date and time	Decision	Made by	Reasons	Reviewed by
e.g. 12 Nov 12:30	*Isolate file server*	*Incident lead*	*Possible lateral spread*	*Technical lead*

PERSONAL DATA BREACH REGISTER (ART. 33(5))

Date aware	Facts	Data and people affected	Effects	Actions taken	Notified authority?	Told individuals?	Reasoning
e.g. 12 Nov 09:40	*Mailbox takeover*	*Client emails, about 120 people*	*Phishing risk*	*MFA, reset, rule removed*	*Yes, 13 Nov*	*Yes, 14 Nov*	*Risk to people, high for bank details*

Draft: notification to the supervisory authority

Authority notification (draft, Art. 33(3))

```
Initial / update notification no. [1]
Controller: [business name, address, registration no.]
Contact point: [name, role, email, phone]
Date and time the breach occurred (or estimate): [ ]
Date and time we became aware: [ ]
Nature of the breach: [confidentiality / integrity / availability; short description]
Categories and approximate number of people: [customers, staff... about N]
Categories and approximate number of records: [ ]
Likely consequences: [e.g. phishing, fraud, loss of confidentiality]
Measures taken or proposed: [containment, investigation, notice to individuals, extra protection
s]
Individuals informed? [yes/no/planned, date]
Cross-border implications: [other member states, if any]
Information still being investigated and expected update date: [ ]
Reason for delay (if more than 72 hours): [ ]
```

Draft: internal one-page summary for the owner

Management summary (draft)

```
What happened in one sentence: [ ]
Current status: [contained / under investigation / recovered]
Personal data affected: [ ]
People affected: [ ]
Our legal position: [record only / authority notified / authority and individuals]
Next deadline: [ ]
Decisions needed from you: [ ]
Costs so far and expected: [ ]
```

Incident severity quick scale

Level 1	Level 2	Level 3	Level 4
Contained scare	**Limited breach**	**Serious breach**	**Crisis**
No personal data affected, or an easily fixed local issue. Log it, learn from it.	Small amount of data or low risk to people. Record it, assess it, probably no notification.	Sensitive data, many people or criminal intent. Authority notification likely, individuals possibly.	Ongoing attack, large-scale data theft or business down. Full response, specialists and legal advice.

Figure 21 Quick severity scale

Plain-English Glossary

The terms you will meet on the way, in alphabetical order.

Awareness	The point at which you have a reasonable degree of certainty that a security incident has compromised personal data. It starts the 72-hour clock.
Availability breach	Personal data is lost or cannot be accessed, for example through ransomware or deletion.
Business email compromise	An attacker uses a hijacked or spoofed mailbox to trick people into paying or sharing data.
Chain of custody	The record of who held a piece of evidence and when, showing it was not altered.

Confidentiality breach	Someone without authority gets access to personal data or a copy of it.
Containment	Actions that limit how far an attack can spread, taken before cleaning up.
Controller	The organisation that decides why and how personal data is processed.
CSIRT	Computer Security Incident Response Team: a national or sector team that handles cyber incidents.
Data subject	The person the personal data is about.
DPO	Data Protection Officer: an independent adviser required in some organisations (Arts. 37 to 39).
Eradication	Removing the attacker's access and tools and closing the weakness they used.
High risk	A level of risk to people serious enough to require telling them directly (Art. 34).
Integrity breach	Personal data is changed without authority.
MFA	Multi-factor authentication: a second proof of identity, such as a code or app approval, in addition to a password.
NIS2	The EU directive on the security of network and information systems, with incident reporting duties for many medium and large organisations.
Personal data breach	A security breach leading to accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data (Art. 4(12)).
Phishing	A deceptive message that tricks someone into revealing credentials or installing malware.
Processor	An organisation that processes personal data on behalf of a controller.
Ransomware	Malware that encrypts files and demands payment, often combined with data theft.
Supervisory authority	The national data protection regulator, such as the CNIL in France.
Tabletop exercise	A talk-through of a made-up incident to test your plan.

Official Sources & Further Reading

Where the legal claims in this book come from, and where to check what applies today.

Always prefer the primary sources below to summaries, including this one. Web addresses change: if a link has moved, search the official site for the title shown. Guidance is updated regularly, so check for the latest version before relying on it.

Primary EU law (EUR-Lex)

- **General Data Protection Regulation (GDPR)**, Regulation (EU) 2016/679. Notably Art. 4(12) (personal data breach), Art. 5(2) (accountability), Art. 28 and 33(2) (processors), Art. 32 (security), Art. 33 (notification to the authority), Art. 34 (communication to individuals), Art. 82 (compensation) and Art. 83 (fines). eur-lex.europa.eu/eli/reg/2016/679/oj
- **NIS2 Directive**, Directive (EU) 2022/2555, on measures for a high common level of cybersecurity, including incident reporting. Applies through national laws: check yours.

Regulators and guidance

- **European Data Protection Board (EDPB)**, Guidelines 9/2022 on personal data breach notification under the GDPR (version 2.0, March 2023), and Guidelines 01/2021 on examples regarding personal data breach notification: edpb.europa.eu
- **Your national data protection authority**: most provide an online breach-reporting form and local guidance. Find yours on the EDPB website.
- **UK Information Commissioner's Office**, announcements on British Airways (16 October 2020, £20 million) and Marriott International (30 October 2020, £18.4 million): ico.org.uk. These were issued under the UK regime, which mirrors the GDPR.
- **No More Ransom**, free decryptors and advice: nomoreransom.org
- **ENISA and your national CSIRT or cyber agency**, for cyber incident guidance and reporting.

> WATCH OUT **What this book could not verify for you**
>
> The Digital Omnibus changes to breach notification (higher threshold, 96-hour deadline, single entry point) were proposals when this book was written, reported mainly by law-firm and vendor commentary, and should be checked against EUR-Lex and the European Parliament's procedure page. NIS2 scope and deadlines vary by national law. The scenarios in this book are fictional. Check each point against the primary source and take advice from a qualified professional before relying on it.

About the Author

Zirlandia Milkovic

Zirlandia Milkovic writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes privacy is not a barrier to ambition but a foundation of trust, and that founders should not need a legal degree to understand the rules that apply to them.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex European rules into simple steps, checklists and templates that busy founders can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Stay in touch

Visit **gdprgard.eu** for free tools, articles and updates, including notes on changes to the rules covered in this book. If this guide helped you, an honest review where you bought it helps other businesses find it.

> AI & PRIVACY **Note to the reader**
>
> This book is educational and not legal advice. Laws and guidance change, so check the sources in the previous section and consult a qualified professional about your own circumstances.


Act fast.
Preserve the evidence.
Decide, document, notify.
ZIRLANDIA MILKOVIC